Operating System Security

Week 5: Auditing and Logging

Auditing and Logging

Effectively we're "detecting security problems".

Motivation:

- Normal users: we trust them, but should verify.
- Attacker: track down what has happened.

Logging vs. Auditing

Logging:

- Record events or statistics to logs
- Example: failed logins, failed su attempts, last login times, system calls, network traffic, etc.

Auditing:

- Analyze log records for meaningful results.
- E.g., manual inspection, intrusion detection, alert correlation, etc.

Relationship:

- Logging provides input to auditing
- Auditing makes sense out of logs

Challenges of Logging & Auditing

Logging:

- Attackers will alter or delete logs of their activities
- Consider: what if the attacker has administrative or root privileges?

Auditing:

- Heavily depends on human interaction
- Some research focuses on automatic extraction of useful information from logs. Some success, but still involves a human.

Logging on Windows Systems

Viewable through the "Event Viewer"

Event logs differ for different variants, but on Windows 10 some of the more important ones:

- System: system crashes, component failures, etc.
- Application: as requested by applications
- Security: logging in and out, system file accesses, etc.
- Applications and Service logs: per-application logs, but mostly unused.
- Also has custom views that can be set up as needed.

Default log size on Windows 10 differs for each log, but is finite and overwrites events when needed.

Logging on Linux

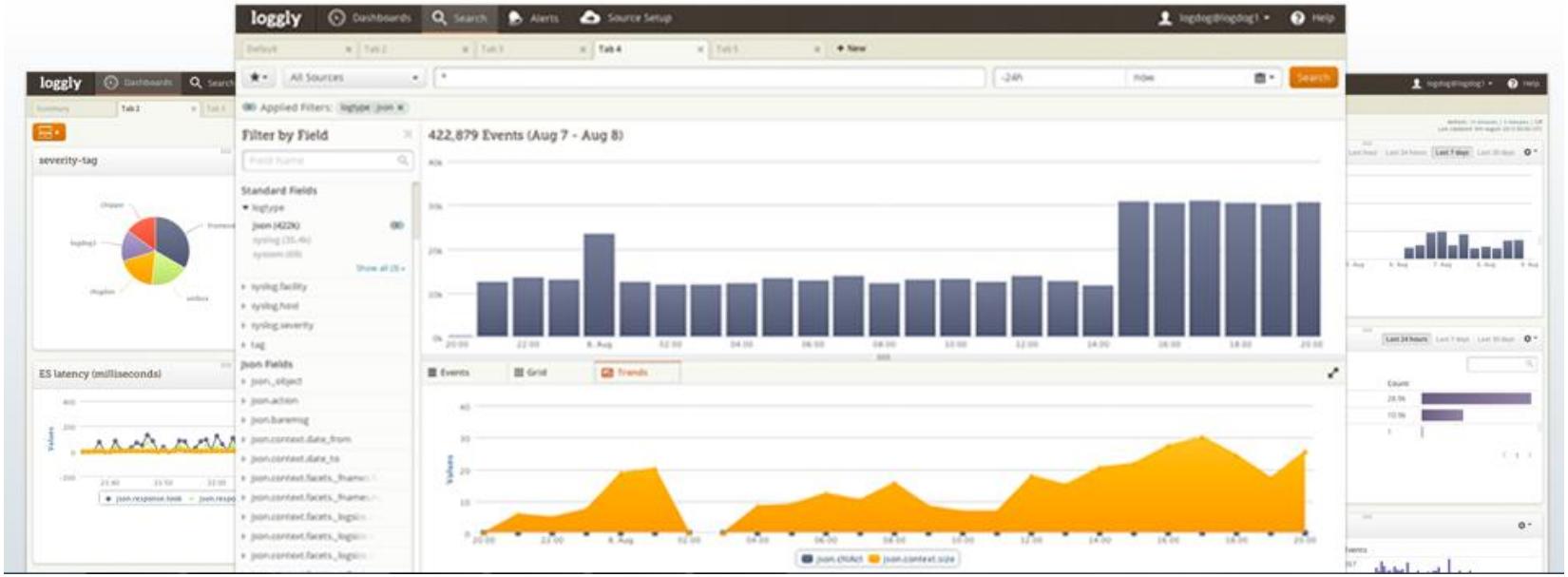
Can use rsyslog (based on UNIX's syslog).

- /etc/rsyslog.conf is a configuration file that specifies what log and where to save.
  - You can open up this file to see all of the logs that get created.
  - You can also set up remote logging to another server through this configuration file. -- this is a good idea! Why?
- rsyslogd is the name of the logging daemon.

Log Visualization

Based on the idea that we always need to have a human in the loop to audit logs – so why not make this task easier?

There are lots of products that do this, e.g., Loggly (http://www.loggly.com, last accessed Jan. 31, 2020):



Issue to consider: should every error be logged ?

Can you think of any examples of when we might not want to log information?

Privacy and Secrets

What is the potential privacy breach in this Java code?

```
public ResultSet execSQL(Connection conn, String sql) {
  Statement stmt = null;
  ResultSet rs = null;
  try {
     stmt = conn.createStatement();
     rs = stmt.executeQuery(sql);
  } catch (SQLException sqe) {
    logger.log(Level.WARNING, "error executing: " + sql, sqe);
  } finally {
    close(stmt);
  }
  return rs;
}
```

Passwords (and/or other private information) can be leaked!

Consider the following code that might call the previous slide's Java function:

```
sqlQuery = "SELECT item FROM users WHERE login = "
        + user.getLogin()
        + " AND password = "
        + user.getPassword()
result = execSQL(connection, sqlQuery);
```

Related to Logging & Auditing: Honeypots

Intended to trap an intruder

A system that is network-connected, but not actually used in any capacity, so no activity is legitimate.

- Helps the auditing process: most logs represent an intrusion, and a more verbose logging level can be used
- On a regular "in-use" machine, a challenge is to determine which logs are related to the intrusion.
- Many honeypots are actually application-level, e.g., for a particular service assumed to be an attractive target

Honeynets are simulated networks of honeypots.

Summary Questions

What is the relationship between auditing and logging?

How do you examine logs in Windows ?

How do you examine logs in UNIX or Linux ?

What is the purpose of a honeypot?

What are some important considerations when setting up logging ?